

Business Continuity Management

Dr. Ruba Alomari

**MITS5600G – Security Policies and Risk
Management**

References

- Today's material is also based on the books:
- **Principles of Incident Response and Disaster Recovery**, 3rd Edition, Michael E. Whitman, Herbert J. Mattord, and Andrew Green, Course Technology, 2021, ISBN-13: 978-0357508329, ISBN-10: 0357508327 url: <https://www.vitalsource.com/referral?term=9780357508442>
- **Principles of Information Security** by Michael Whitman and Herbert Mattord, 7th Edition, 2021 ISBN-10 : 035750643X, ISBN-13 : 978-0357506431, url: <https://bookshelf.vitalsource.com/books/9780357506561>

Recall – Last Week – Why is Supply Chain Security Important?

- Supply chain security is critical for several reasons:
 1. **Protection of Sensitive Information:** Prevents compromise of sensitive information such as customer personal information and proprietary product data.
 2. **Integrity of Goods:** Ensures the integrity of goods being delivered. Especially in industries like pharmaceuticals, where counterfeit or tampered with products can pose significant health risks.
 3. **Business Reputation:** Maintains trust among customers and partners through reliable and secure supply chain practices.



Recall – Last Week – Strategies for Enhancing Supply Chain Security

- Strategies for Enhancing Supply Chain Security:
 1. Risk Assessment and Management
 2. Technology Utilization
 - Blockchain
 - Encryption and IDPS
 3. Stakeholder Collaboration

Topics

- Emergency Preparedness
- Business Continuity Risk Management
- The Business Continuity Plan
- Business Continuity and Disaster Recovery in Cloud Services
- Plan Testing and Maintenance

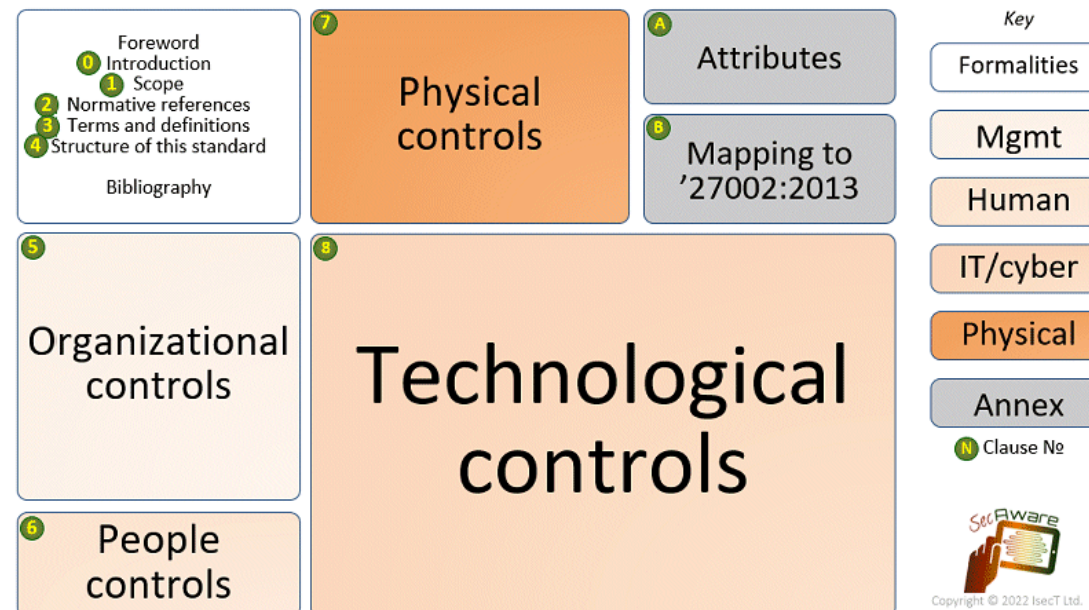
Topics

- Emergency Preparedness
- Business Continuity Risk Management
- The Business Continuity Plan
- Business Continuity and Disaster Recovery in Cloud Services
- Plan Testing and Maintenance

FYI: ISO 27002:2022

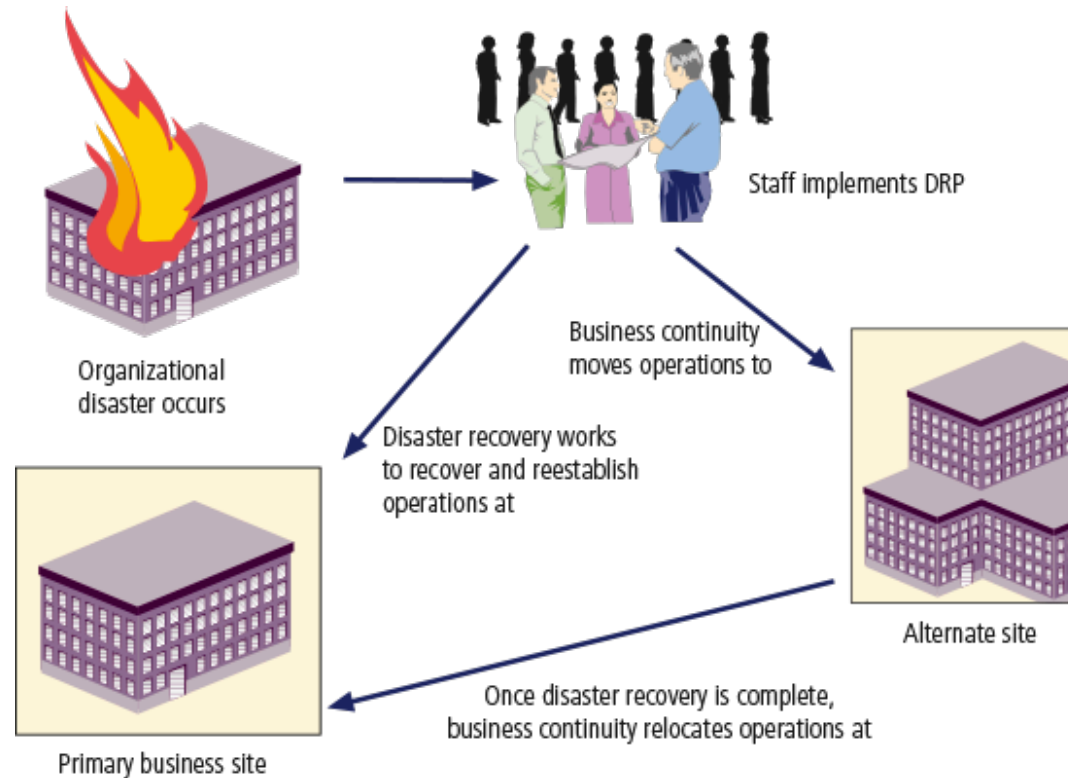
- **Section 5.29 (Organizational Controls):** Information security during disruption
- **Section 8.14 (Technological Controls):** Redundancy of information processing facilities

ISO/IEC 27002:2022



What Constitutes a “Disaster”? – General

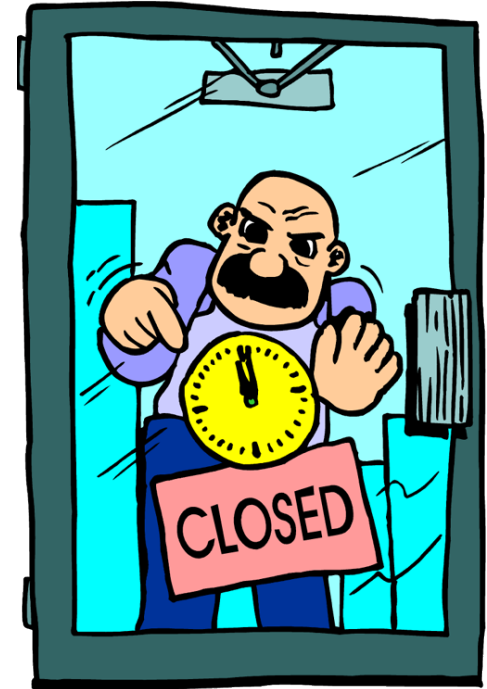
- Any event that results in damage or destruction, loss of life, or drastic change to the environment.



Business Continuity vs. Disaster Recovery Objective

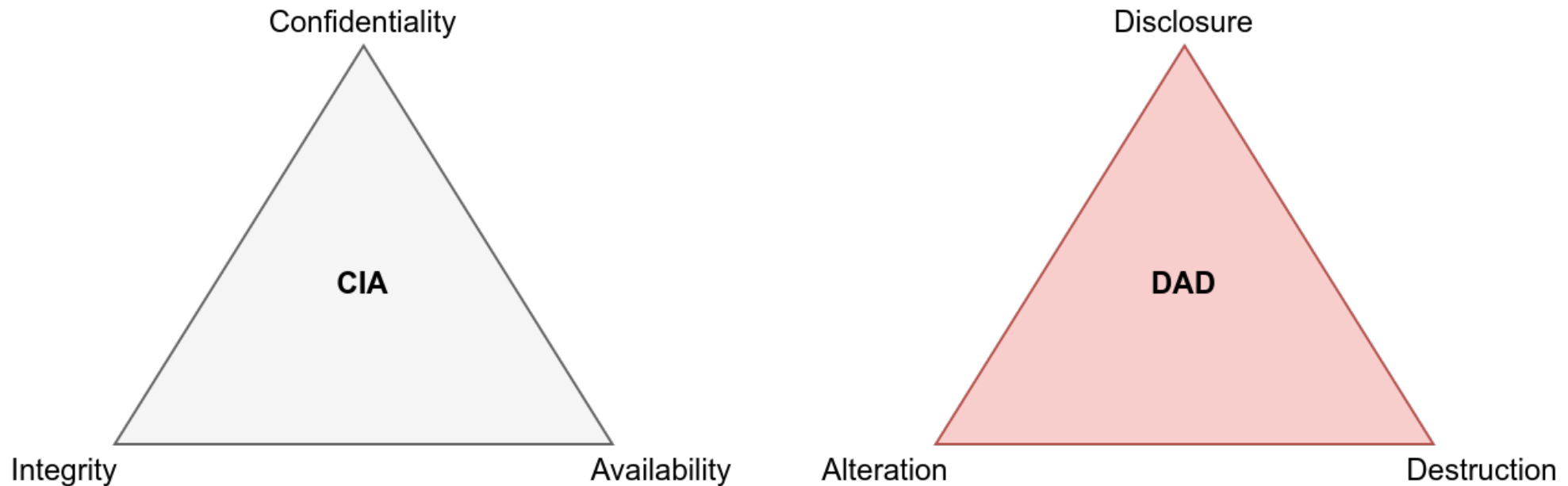
What Constitutes a “Disaster”? – Business

- In a business context, a disaster is an unplanned event that has the potential to result in one (or all) of the following:
 1. Disrupt the delivery of mission-critical services and functions
 2. Jeopardize the welfare of employees, customers, or business partners
 3. Cause significant financial harm

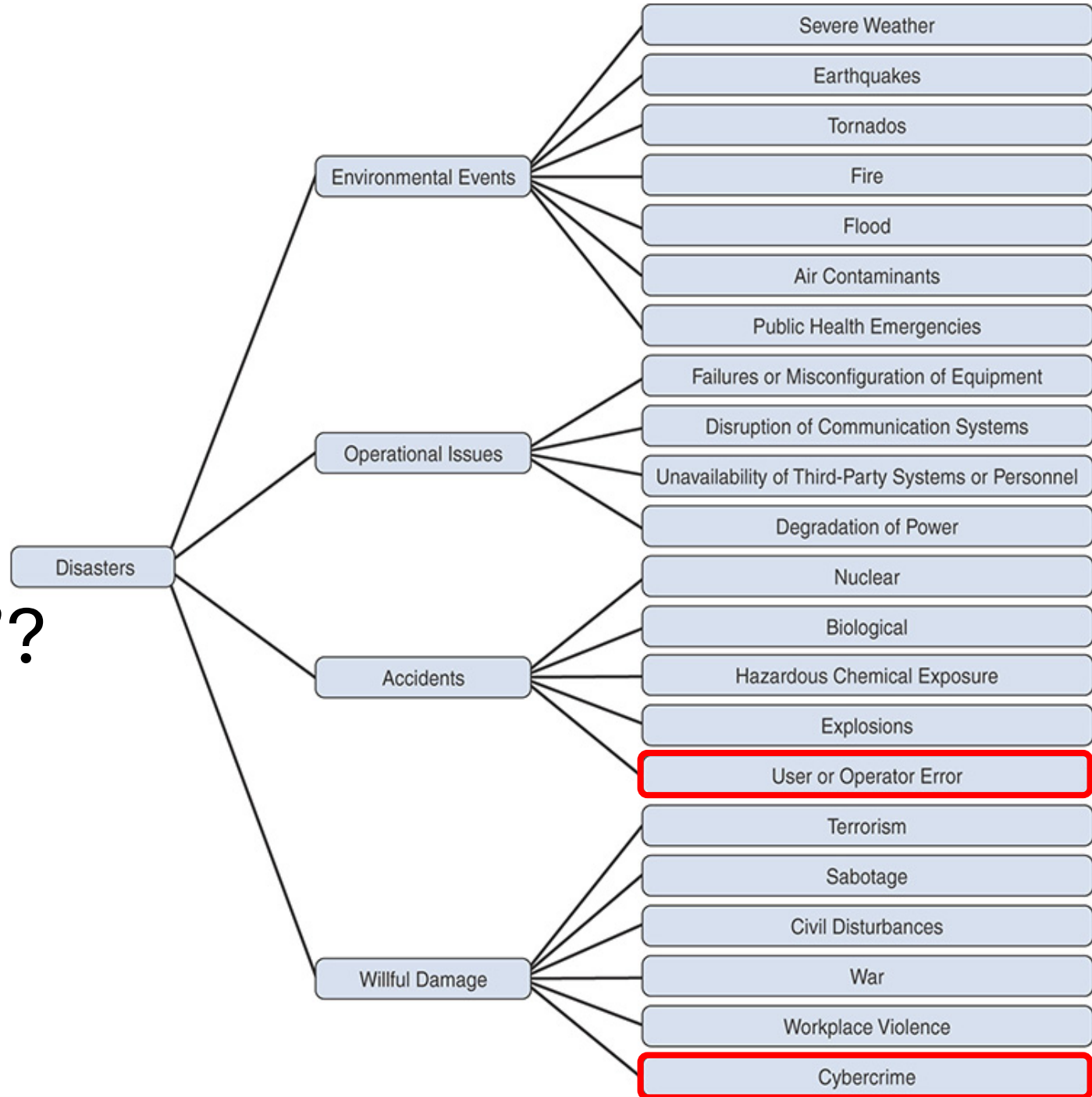


What Constitutes a “Disaster”? – Security

- From a security perspective, a disaster manifests itself as a **sustained disruption** of system availability, confidentiality or integrity controls.



What May Cause a “Disaster”?



2018 Hawaii False Missile Alert

- On January 13, 2018, there was a false ballistic missile alert sent to all Hawaii residents
 - Human error during routine drill, employee mistook test for real threat
 - "THIS IS NOT A DRILL" triggered widespread panic
 - Correction Delay: 38 minutes to issue a retraction
 - Aftermath:
 - Employee fired; Hawaii Emergency Management Agency (HI-EMA) administrator resigned
 - Two-person verification rule implemented
 - FCC recommended alert system improvements

2018 Hawaii false missile alert



A screenshot of the alert as displayed on an [iOS device](#)

Date	January 13, 2018
Time	08:08:23 (HST)
Duration	38 minutes
Location	Hawaii , United States
Type	False alarm



Estimated maximum range of some [North Korean missiles](#)

Hawaii Gov. David Ige slow to correct false missile alert because he couldn't log onto Twitter

Ige said he couldn't access his Twitter log-in for 17 minutes to assure residents that the Jan. 13 drill was actually a false alarm.



Gov. David Ige (left) speaks at a news conference about the missile alert that rattled Hawaii in the morning hours of Jan. 13, 2018. KHNL

On Monday, when asked about the delay, Ige, a Democrat, told reporters he simply couldn't log on to Twitter.

"I have to confess that I don't know my Twitter account log-ons and the passwords, so certainly that's one of the changes that I've made," Ige said after delivering the State of the State address, which made

no mention of the missile alert blunder.

Regardless, many residents, [cowering in basements or crammed inside bathtubs](#), were not checking Ige's social accounts as they awaited what they feared would be a deadly missile strike from North Korea. And it wasn't until [38 minutes after the initial alert went out](#) that the Hawaii Emergency Management Agency finally sent out an update: "False Alarm. There is no missile threat or danger to the State of Hawaii."

The incident has prompted a probe by the Federal Communications Commission and a slew of changes to the Emergency Alert System and the Wireless Emergency Alert used by Hawaii's agency, which routinely does internal tests of the system. 

Resilient Organizations

- A resilient organization can **quickly adapt and recover** from changes to the environment.
- Resilience doesn't just happen; it needs lots of planning and requires:
 - The support of enterprise **leadership**
 - A resilient **culture** based on empowerment, purpose, trust, and accountability
 - **People** who are properly selected, motivated, equipped, and led
 - **Agility** and flexibility via a distributed workplace model and a robust and collaborative IT structure
 - **Alternative workplace techniques** provide the level of workplace flexibility and agility that is essential for mitigating the risk of catastrophic or disruptive incidents.

Regulatory Requirements

- Regulatory requirements for business continuity management (BCM) vary by **industry** and **region**, reflecting the importance of ensuring that organizations can continue to operate in the face of disruptions.
- These regulations are designed to
 - protect the economy,
 - ensure the stability of markets,
 - safeguard customer interests,
 - and maintain the delivery of critical services.



Regulatory Requirements - Examples

- **Financial Sector:**

- Basel III: Requires risk management and BCM plans for banks – Canada aligns with Basel III
- PSD2 (Payment Services Directive 2 - EU): Enforces operational/security risk management including BCM for payment service providers.

- **Healthcare:** Requires contingency plans (e.g., backup, disaster recovery) to protect patient data and ensure care continuity. Examples: HIPAA (US), PHIPPA (Canada, Ontario).

- **Energy & Utilities (North America):**

- Example: NERC (North American Electric Reliability Corporation): Sets standards for recovery of critical electric infrastructure.

- **Aviation (Global):**

- Example: ICAO (International Civil Aviation Organization): Establishes emergency planning and crisis management standards.

- **Cross-Industry Framework:**

- Example: ISO 22301: International BCM standard adopted to meet/exceed regulatory compliance across sectors



AlOmari © 2025



**PHIPA &
PIPEDA**
COMPLIANT



22301

16

In Practice

Emergency Preparedness Policy

Policy Synopsis: Demonstrate the organization's commitment to emergency preparedness and business continuity.

Policy Statement:

- An emergency preparedness and business continuity strategy that ensures the safety of employees and customers, enables the company to perform essential functions absent normal operating conditions, protects organizational assets, and meets regulatory requirements is an organizational priority.
- The company will designate necessary resources to develop and maintain emergency preparedness and business continuity plans and procedures.

Topics

- Emergency Preparedness
- **Business Continuity Risk Management**
- The Business Continuity Plan
- Business Continuity and Disaster Recovery in Cloud Services
- Plan Testing and Maintenance

Business Continuity Risk Management /1

- Continuity planning is simply the **good business practice** of ensuring the execution of essential functions.
- Continuity planning is an integral component of organizational risk management.



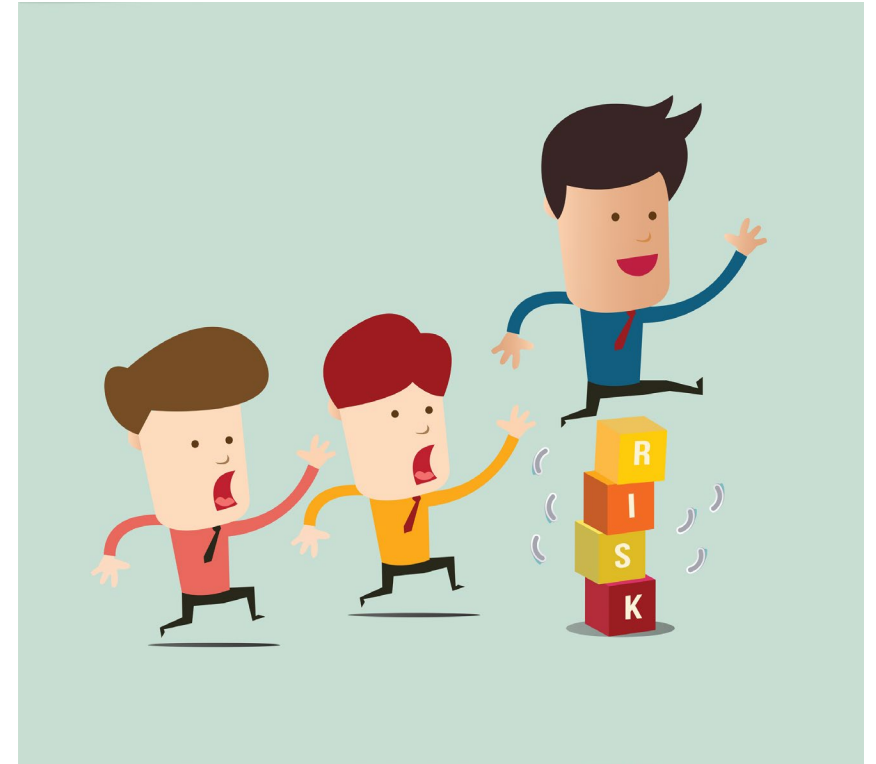
Business Continuity Risk Management /2

- Recall: Week 4 - Governance and Risk Management:
- Risk management is defined as the process of identifying, analyzing, assessing, and communicating risk and accepting, avoiding, transferring, or controlling it to an acceptable level considering associated costs and benefits of any actions taken.



Business Continuity Risk Management /3

- Risk management for continuity of operations requires that the organization:
 - identify threats (**threat assessment**),
 - determine risk (**risk assessment**),
 - and assess the internal and external impacts of the disruption of mission-critical or essential services (**business impact assessment**).



Business Continuity Threat Assessment

- Business continuity threat: A potential danger to an organization.
 - Threats can be business-specific, local, regional, national, or even global.
- The objective of a business continuity threat assessment is to **identify viable threats**.
- Identified threats are rated in terms of the **likelihood** of occurrence and potential **impacts**.



Threat Modeling

- Threat modeling takes into account **historical** and **predictive geographic, technological, physical, environmental, third-party, and industry factors** such as the following:
 1. What type of disasters have occurred in the community or at this location?
 2. What can happen due to the geographic location?
 3. What could cause processes or information systems to fail?
 4. What threats are related to service provider dependency?
 5. What disasters could result from the design or construction of the facility or campus?
 6. What hazards are particular to the industry sector?

Threat Modeling

There are five major threat modeling steps:

1. Defining security requirements.
2. Creating an application diagram.
3. Identifying threats.
4. Mitigating threats.
5. Validating that threats have been mitigated.



<https://www.microsoft.com/en-us/securityengineering/sdl/threatmodeling>

Cybersecurity Analyst

DCI Group of Companies
Hybrid work in Brampton, ON L6T 1E4

\$80,000 a year

- Lead information security assessment and conduct security testing including penetration testing, vulnerability mitigation, **threat modeling**, authentication,...

More...

Specialist, Cyber Security

Bell
Ottawa, ON

Full-time

- Threat **Modeling**: Conduct **threat modeling** exercises, in collaboration with BUs and affiliates, to identify potential vulnerabilities and develop mitigation...

More...

Application Security Engineer

Sectigo
Hybrid work in Ottawa, ON

Full-time **Weekends as needed +2**

- Promote a secure-by-design culture, advocating for best practices in secure coding, **threat modeling**, and vulnerability management to protect against potential...

Specialist, Cyber Security

Bell [🔗](#) | Ottawa, ON

You must create an Indeed account before continuing to the company website to apply

Apply now [🔗](#)



- Security Requirements Gathering: Collaborate with stakeholders, including BUs and affiliates, to define and document security requirements based on threat modeling, risk assessments, and industry best practices, tailoring solutions to specific needs.
- Architecture and Design: Participate in the design and architecture phases of projects, providing security expertise and guidance to ensure secure design principles are implemented, considering the perspectives of BUs and affiliates.
- **Threat Modeling: Conduct threat modeling exercises, in collaboration with BUs and affiliates, to identify potential vulnerabilities and develop mitigation strategies that align with business priorities.**
- Security Standards: Develop and maintain security standards, guidelines, and best practices for secure coding, configuration, and deployment, ensuring they are easily understood and adopted by BUs and affiliates.
- Training and Awareness: Develop and deliver security training and awareness programs tailored to the specific needs of different BUs and affiliates.
- Collaboration: Work closely with cross-functional teams, BUs, and affiliates to ensure security is integrated throughout the SDLC and across the organization.
- Documentation: Create and maintain comprehensive documentation of security designs, configurations, and procedures, ensuring it is

Threat Modeling Example – Biometric System

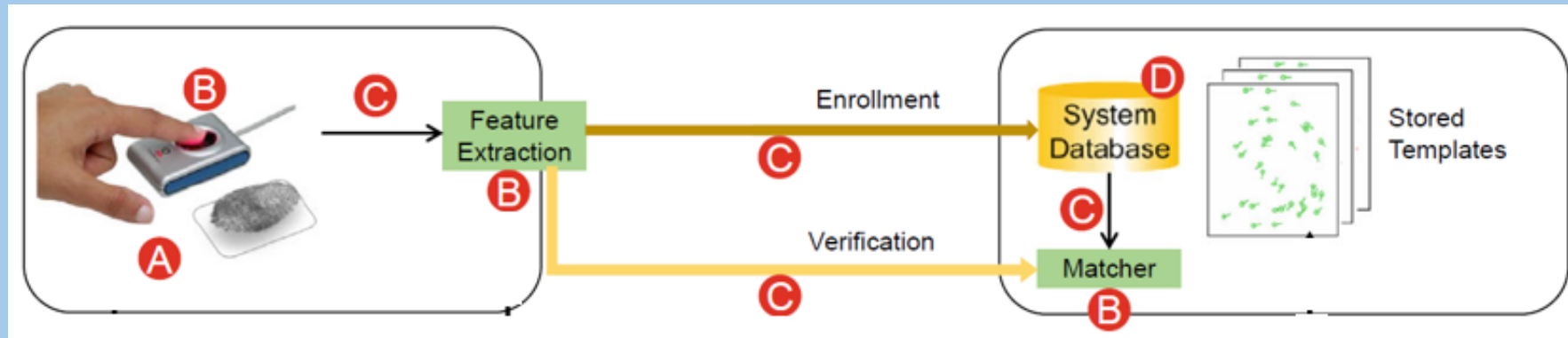
1- Defining Security Requirements

- **System Goal:** To authenticate users using biometric traits (e.g., fingerprints or facial recognition) for access to a secure system.
- **Security Requirements:**
 1. Ensure biometric data (templates) is confidential and cannot be reused or reverse-engineered.
 2. Detect and prevent spoofing or replay of biometric inputs.
 3. Ensure only valid, verified users can be enrolled.
 4. Prevent unauthorized access via system manipulation or insider threats.
 5. Maintain availability and accuracy of authentication services.



Threat Modeling Example – Biometric System

- 2- Creating an application diagram.

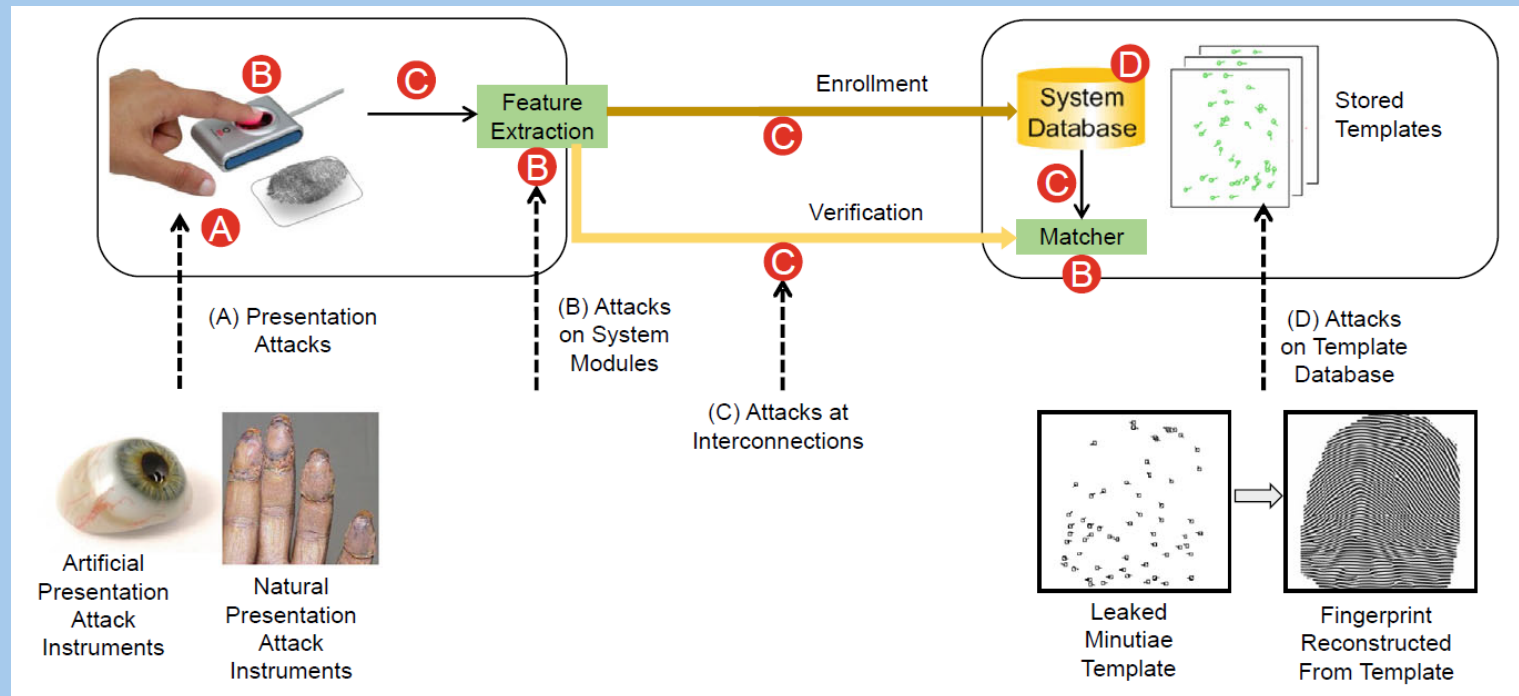


- **A** user-biometric system interface
- **B** biometric system modules
- **C** interconnections between biometric modules, and
- **D** template database

Figure Credit: Introduction to biometrics. Springer Science & Business Media. – by Jain, Ross, & Nandakumar

Threat Modeling Example – Biometric System

■ 3- Identifying threats.



The 4 major points of vulnerability are: **A** user-biometric system interface, **B** biometric system modules, **C** interconnections between biometric modules, and **D** template database

Figure Credit: Introduction to biometrics. Springer Science & Business Media. – by Jain, Ross, & Nandakumar

Threat Modeling Example – Biometric System

■ 3- Identifying threats.

Component	Threat	Category
Biometric Sensor (A)	Presentation attacks (fake finger, photo)	Intrinsic / Presentation Attack
Feature Extractor (B)	Modification, fault injection	Attacks on System Modules
Communication channels (C)	Replay, MITM, digital injection	Attacks at Interconnections
Template Database (D)	Leakage, tampering	Attacks on Template DB
Enrollment process	Fraudulent enrollment, exception abuse	Human-enabled Attack
Admin/staff involvement	Collusion, negligence, coercion	Human-enabled Attack

Threat Modeling Example – Biometric System

■ 4- Mitigating threats.

Threat	Mitigation
Fake biometric input	Use liveness detection, multi-factor authentication
Feature extractor tampering	Secure module execution, use checksums or signed code
Replay attacks	Include session tokens, timestamps, nonces
MITM/digital injection	Encrypt communication, use mutual TLS
Template tampering/leakage	Encrypt templates, store in HSMs, hash comparisons
Enrollment fraud	Require official ID + biometric verification
Insider threats (collusion/coercion)	Audit logs, role-based access, 4-eyes principle

Threat Modeling Example – Biometric System

- **5-Validating that threats have been mitigated.**
 1. **Penetration Testing:** Simulate attacks like spoofing, replay, and template tampering.
 2. **Security Code Review:** For the biometric modules and data flow encryption.
 3. **Auditing & Logging Review:** Ensure suspicious behaviors (e.g., multiple failed matches, high enrollment rate) are caught.
 4. **Compliance Checks:** Match against ISO/IEC 30107-3 (biometric presentation attack detection).

Threat Assessment – Historical – Example

- Identified threats are rated in terms of the **likelihood** of occurrence and potential **impacts**.

TABLE 12-1 Threat Assessments: Historical

Threat Category	Threat	Description	Likelihood Scale 1–5 [5=highest]	Impact Scale 1–5 [5=highest]	Impact Description	Inherent Risk (L×I)
Environmental	Wildfire	Wildfire consumed 15,000 acres approximately 50 miles northwest of HQ.	4	5	Campus fire	20 (High)
Service provider dependency	Disruption of Internet connectivity	Multiple periods of ISP downtime or extreme latency occurred.	4	5	Disruption of external mail, VPN connectivity, and cloud-based applications	20 (High)
Service provider dependency	Brownouts	Summer temperatures and corresponding air-conditioning usage consistently result in brief periods of low power.	3	5	Power fluctuations with the potential to damage equipment	15 (Medium)
Location	Flood	Flash flooding is an annual occurrence on Highway 16.	5	2	Campus not affected, although deliveries and personnel may be	10 (Low)

Business Continuity Risk Assessment

- Business continuity risk assessment **evaluates** the sufficiency of controls to prevent a threat from occurring or to minimize its impact.

TABLE 12-2 Sample Wildfire Risk Assessment

Threat	Area wildfires resulting in personnel evacuation and potential destruction
Inherent risk	High (as determined by the threat assessment)
Control Assessment	
Physical controls	Fire berm around the campus Contract with local firm for quarterly removal of flammable shrubs, leaves, dead limbs, and twigs within a 1,000-foot zone
Building controls	Fireproof construction Sensor alarms with fire department (FD) notification Fire and smoke sensors and sprinklers throughout the building Fire safety maps throughout the building Lighted emergency exits No outside flammable substances stored near the building
Data center controls	Sensor alarms with FD notification Clean agent fire suppression system Water mist system
Personnel controls	Evacuation plans Fire drills conducted quarterly
Technology controls	Secondary data center 300 miles from primary campus Near-time data replication Secondary data center that can support 200 concurrent remote users
Financial controls	Fire and hazard insurance policy Business disruption insurance policy
Control assessment	Satisfactory
Identified vulnerabilities	Gas-powered generator (as gas fumes are combustible)
Residual risk	Elevated
Risk reduction recommendation	Replace gas-powered generator with diesel-powered generator

Business Impact Assessment (BIA)

- The objective of a business impact assessment (BIA) is to identify essential services/processes and recovery time frames.
- Asks the question: **If an attack succeeds, what do you do next?**
- A BIA incorporates three metrics
 - Maximum tolerable downtime (MTD)
 - Recovery time objective (RTO)
 - Recovery point objective (RPO)



BIA in Contingency Planning Hierarchies

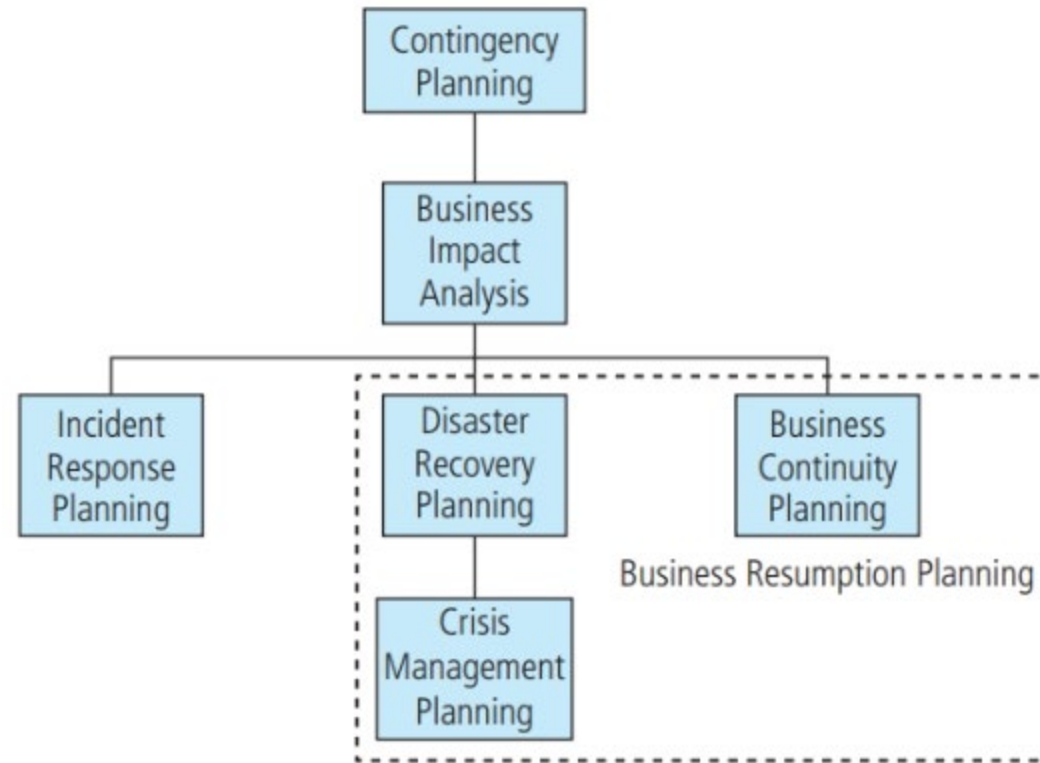


Figure 5-1 Contingency planning hierarchies

Source: Principles of Information Security by Michael Whitman and Herbert Mattord, 7th Edition, 2021, ISBN-13: 978-0357506431

BIA Steps

- A business impact analysis is a multistep collaborative activity that should include business process owners, stakeholders, and corporate officers.
 1. **Step 1:** Identify essential business services and processes.
 - 1A. Determine the maximum tolerable downtime for each service.
 2. **Step 2:** Identify supporting infrastructure, information systems, and dependencies.
 - 2A. Determine recovery time objectives and recovery point objectives.
 3. **Step 3:** Compare to current recovery capability.
 - 3A. Document the gap between desired and current capabilities.
 4. **Step 4:** Have stakeholders review the report for accuracy.
 5. **Step 5:** Present the BIA to management for approval.

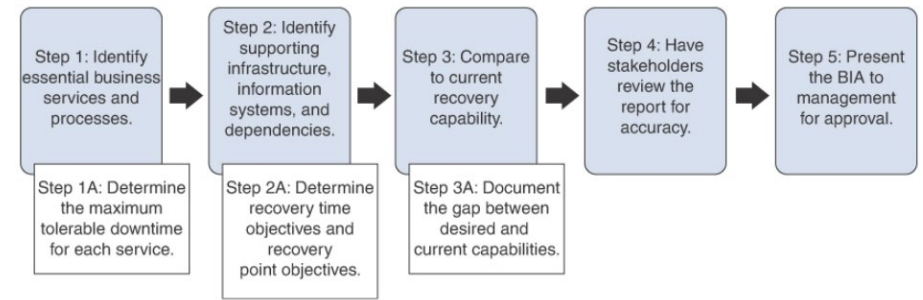


FIGURE 12-2 Business Impact Analysis

Maximum Tolerable Downtime (MTD)

- The maximum tolerable downtime (MTD) is the total length of time an essential business function can be unavailable **without causing significant harm** to the business.

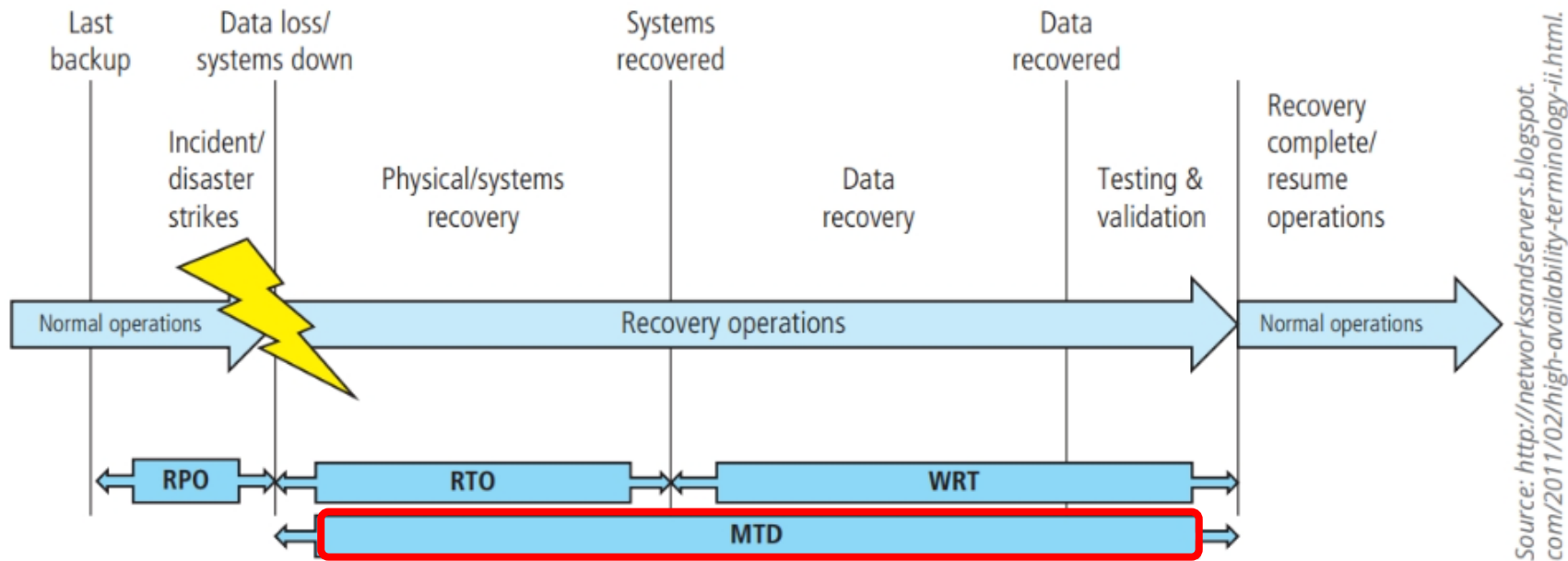


Figure 5-4 RTO, RPO, MTD, and WRT

Recovery Time Objective (RTO)

- The recovery time objective (RTO) is the maximum amount of time a system resource can be unavailable before there is **an unacceptable impact on other system resources** or business processes.

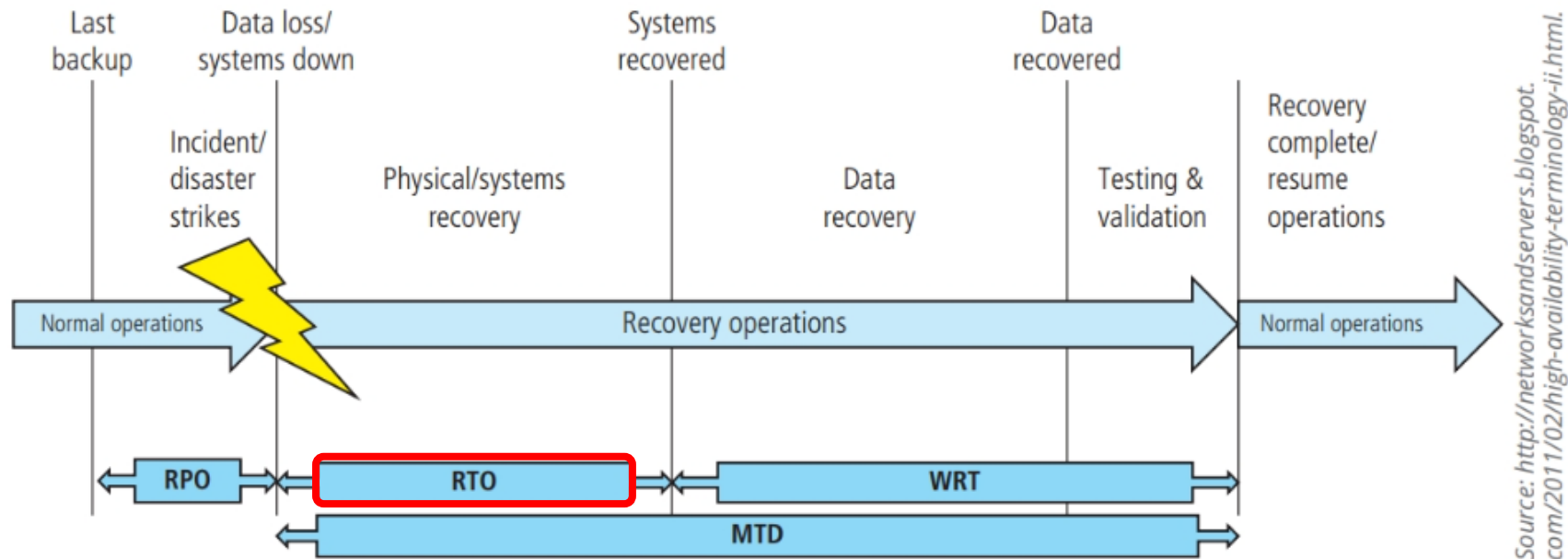


Figure 5-4 RTO, RPO, MTD, and WRT

Recovery Point Objective (RPO)

- The recovery point objective (RPO) is the point in time, prior to a disruption or system outage, to which data can be recovered (in other words, the acceptable data loss).

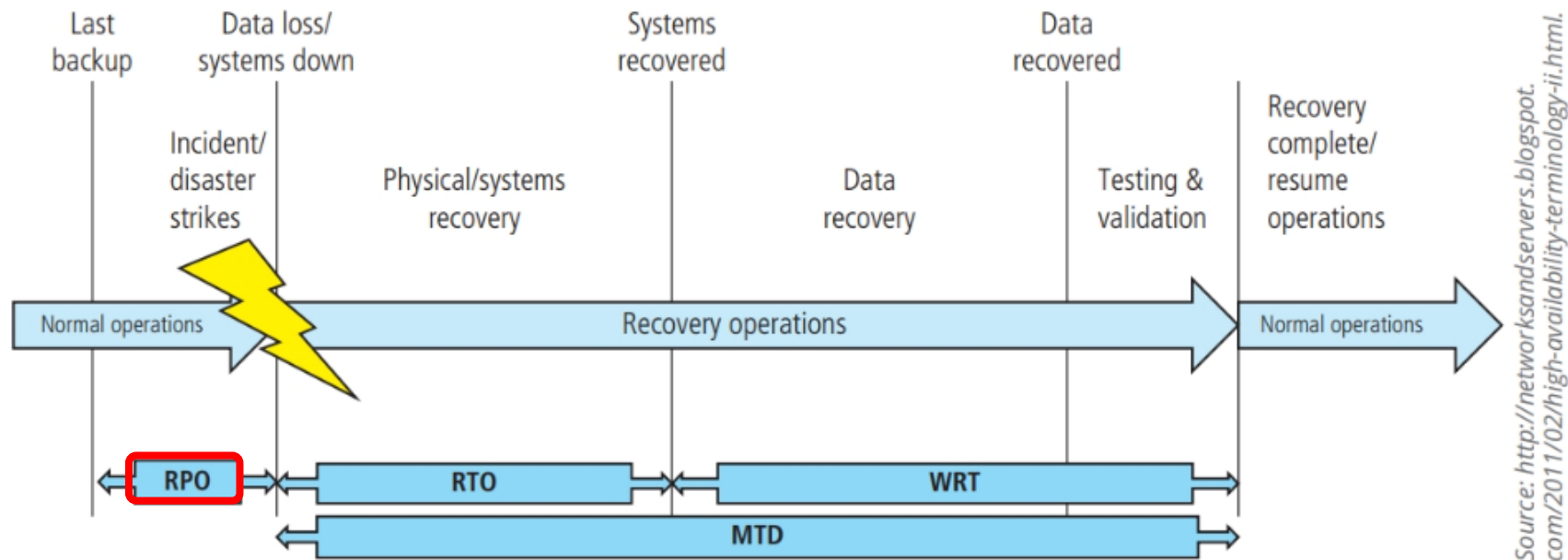


Figure 5-4 RTO, RPO, MTD, and WRT

RTO vs. RPO

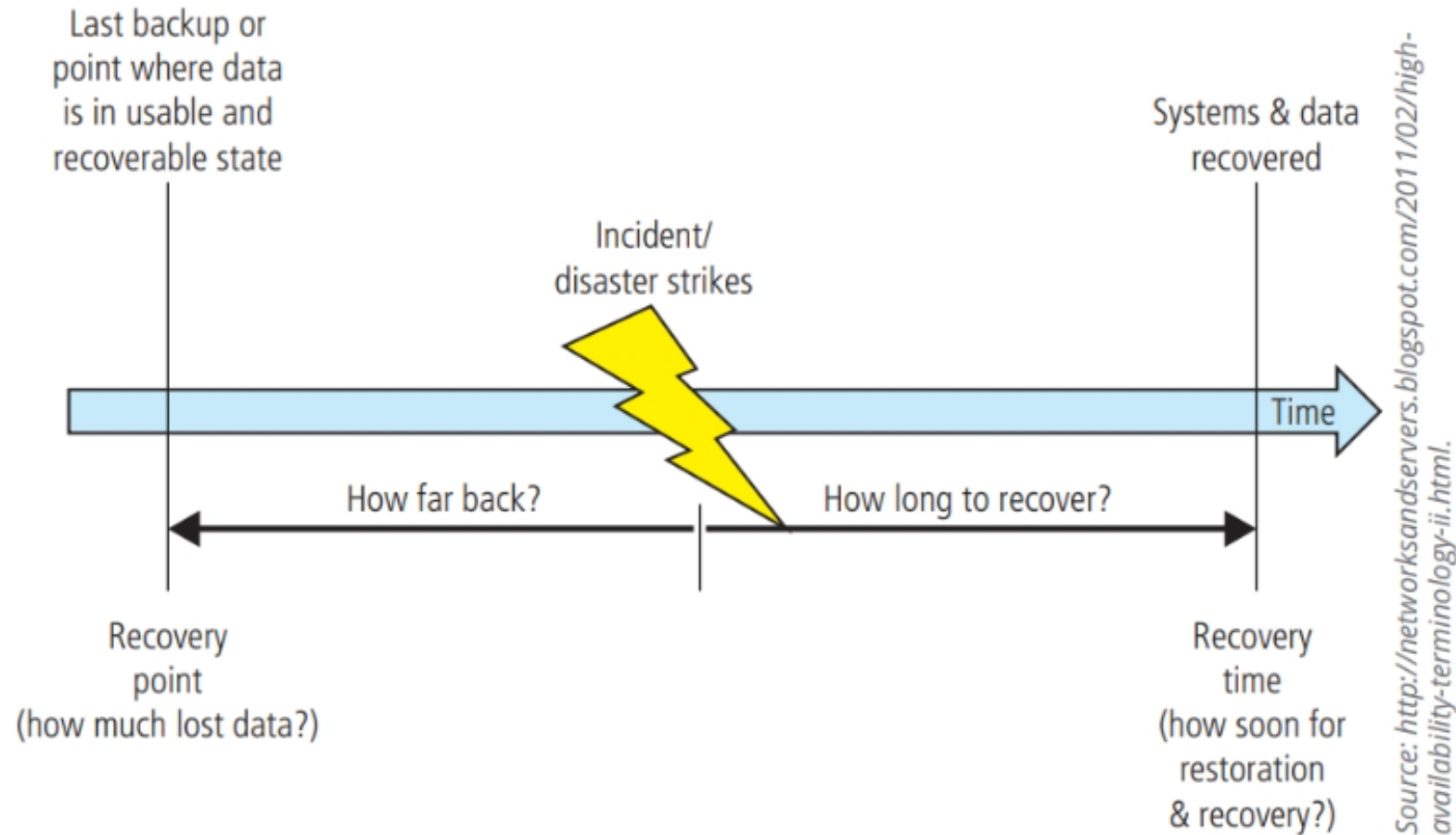
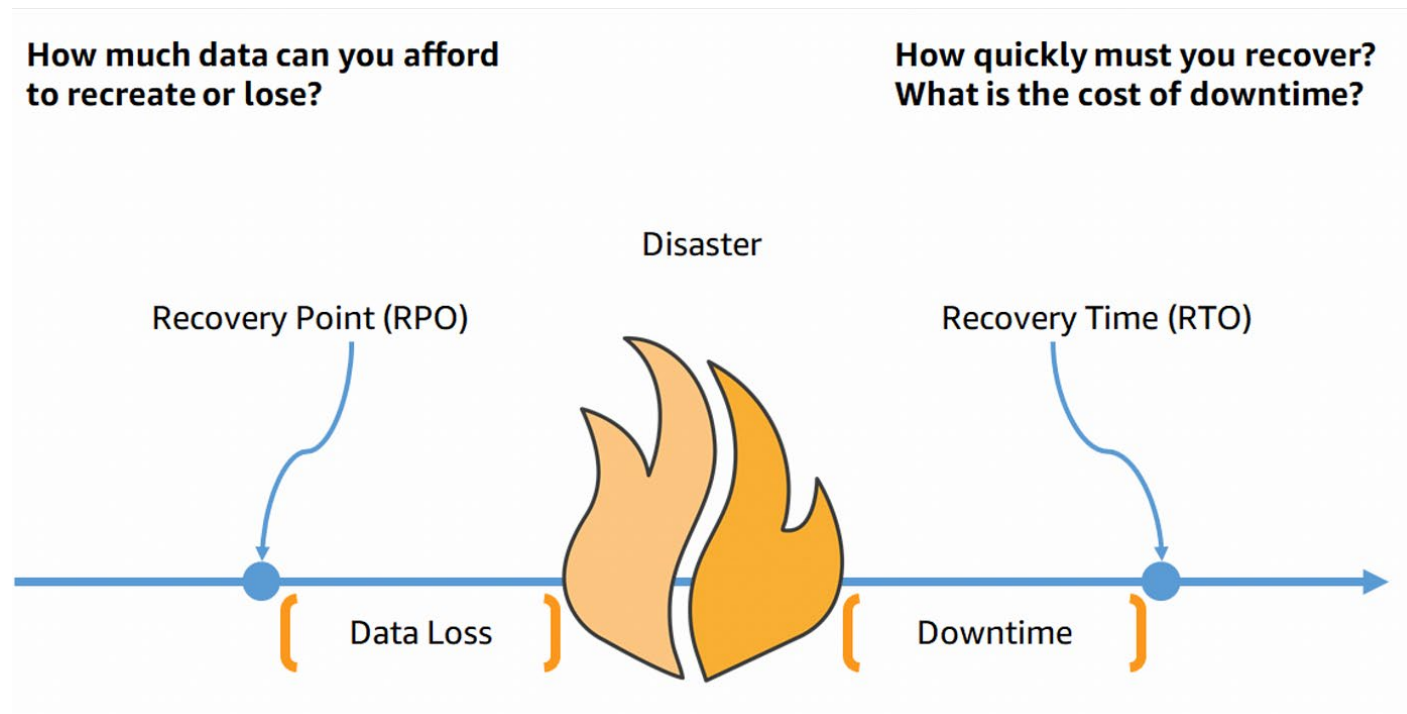


Figure 5-3 RTO vs. RPO

RTO vs. RPO



Work Recovery Time (WRT)

- The amount of effort needed to make business functions work again after the technology element is recovered.

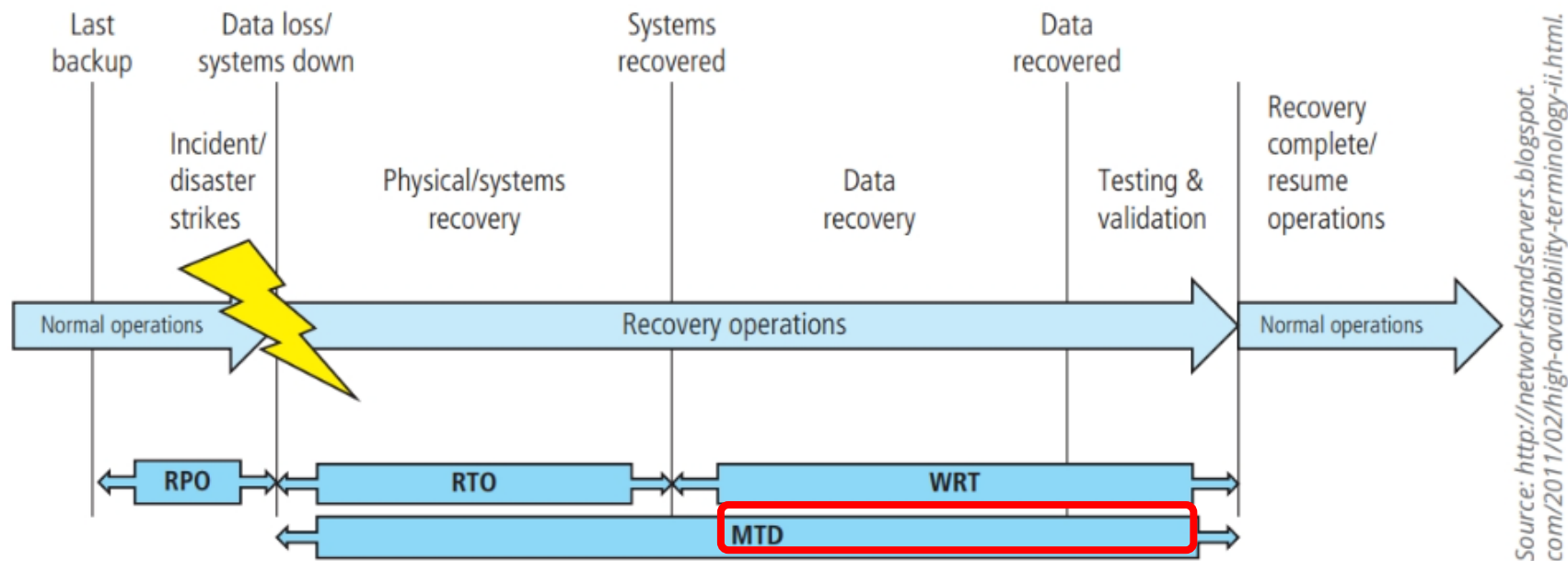


Figure 5-4 RTO, RPO, MTD, and WRT

Cost Balancing

- The longer an interruption to system availability continues, the more impact it will have on the organization and its operations.
- When plans require a short RTO, the solutions will usually be more expensive to design and use.
- In a perfect world, every essential system would be either redundant or available for immediate or near-time recovery. In reality, no organization has unlimited financial resources.

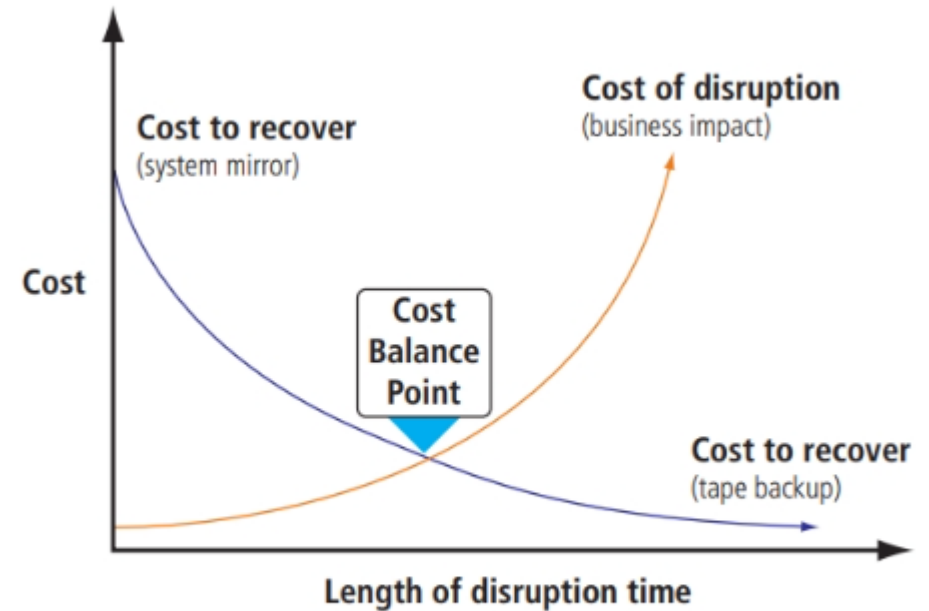


Figure 5-5 Cost balancing

BIA for a Sample Information System

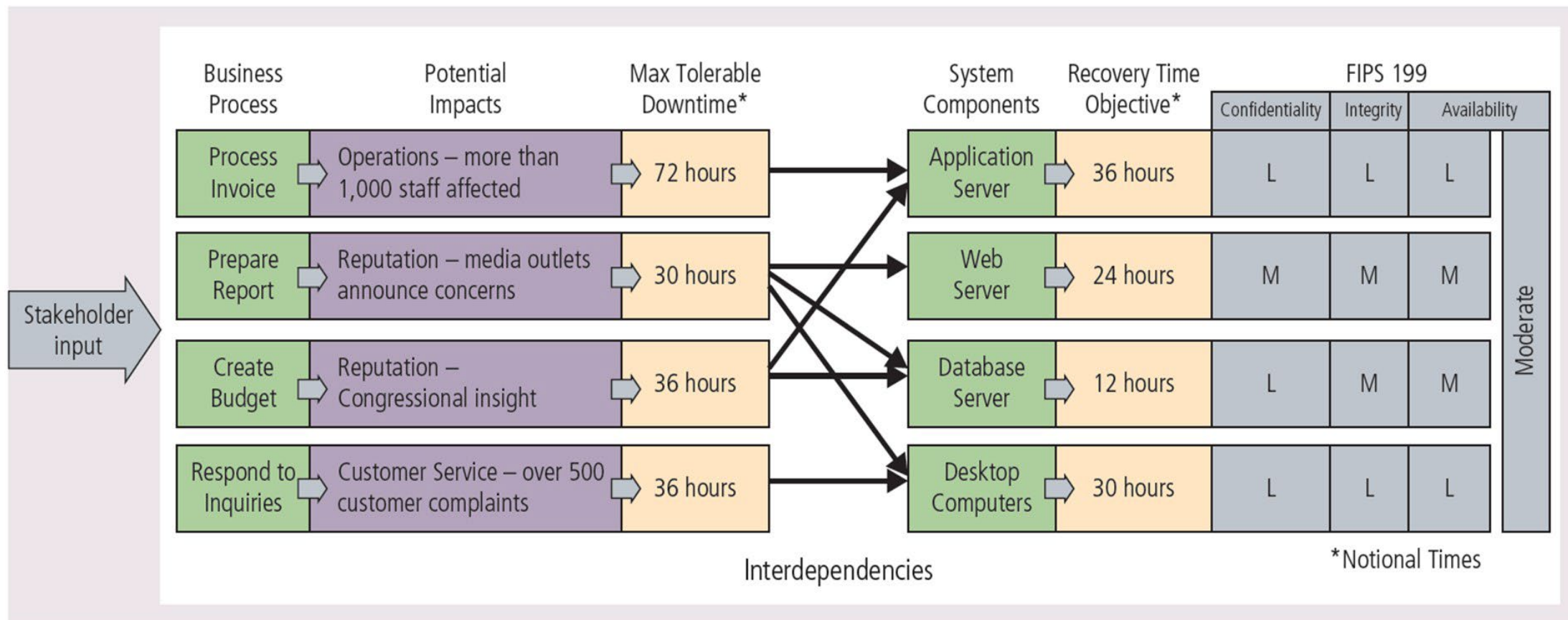


Figure 2-3 Business impact analysis

TABLE 12-3 Business Impact Assessment: Customer Communications

Essential Business Process or Service: Customer Communications			
Delivery Channel	Call Center	Website	Email
Required infrastructure	Voice circuits or IP telephony Wide-area network power Unified communications via cloud services	Internet access	Internet access Wide-area network power
Required devices/information systems	IP phone system Call center system Remote worker systems	Hosted externally	Email system, including email application servers and gateway filters Authentication servers
Third-party dependencies	Telco voice circuits or IP telephony services	Web hosting company Internet service provider (ISP)	DNS propagation
Maximum tolerable downtime (MTD)	5 minutes	Need to update the site within 60 minutes	60 minutes
Recovery time objective (RTO)	Immediate	30 minutes	45 minutes
Recovery point objective (RPO)	12 hours for historical data	24 hours for website content	No acceptable data loss
Current capability	All calls automatically rerouted to the secondary data center Redundant call center system located at secondary data center Statistical data restored from backups, with data replicated every 4 hours	Localized disaster would not impact the website	Redundant fully replicated email infrastructure located at the secondary data center; with access to the secondary data center, external email will not be impacted Incoming email will be delayed approximately 15 minutes, which is the time it takes for an MX record to be updated
Identified issues/points of failure	Relocation of call center staff located from primary location will take a minimum of 8 hours	Administrative access (required for updating) is restricted to specific IP addresses, and updating the access list is a third-party function, with a service-level agreement (SLA) level of 30 minutes	If the primary campus is available, the impact is minimal, but if the primary campus is unavailable, only users with remote access capability will be able to use email
Capability delta	755 minutes	0	+ 30 minutes
Data loss delta	0	0	0

In Practice

Business Impact Assessment

Synopsis: The organization requires and assigns responsibility for an annual business impact assessment (BIA).

Policy Statement:

- The Chief Operating Officer is responsible for scheduling an enterprise-wide annual BIA. System owner participation is required.
- The BIA will identify essential services and processes, where essential is defined as meeting one or more of the following criteria:
 - It is required by law, regulation, or contractual obligation.
 - Disruption would be a threat to public safety.
 - Disruption would result in an impact on the health and well-being of employees.
 - Disruption would result in irreparable harm to customers or business partners.
 - Disruption would result in significant or unrecoverable financial loss.
- For each essential service and/or process, the maximum tolerable downtime (MTD) will be documented. The MTD is the total length of time an essential function or process can be unavailable without causing significant harm to the business.
- For each essential service and/or process, supporting infrastructure, devices/information systems, and dependencies will be identified.
- Recovery time objectives (RTOs) and recovery point objectives (RPOs) for supporting infrastructure and devices/information systems will be documented.
- Current capability and capability delta will be identified. Deviations that put the organization at risk must be reported to the Board of Directors.
- The Chief Operating Officer, the Chief Information Officer, and the Business Continuity Team are jointly responsible for aligning the BIA outcome with the business continuity plan.

Topics

- Emergency Preparedness
- Business Continuity Risk Management
- The Business Continuity Plan
- Business Continuity and Disaster Recovery in Cloud Services
- Plan Testing and Maintenance

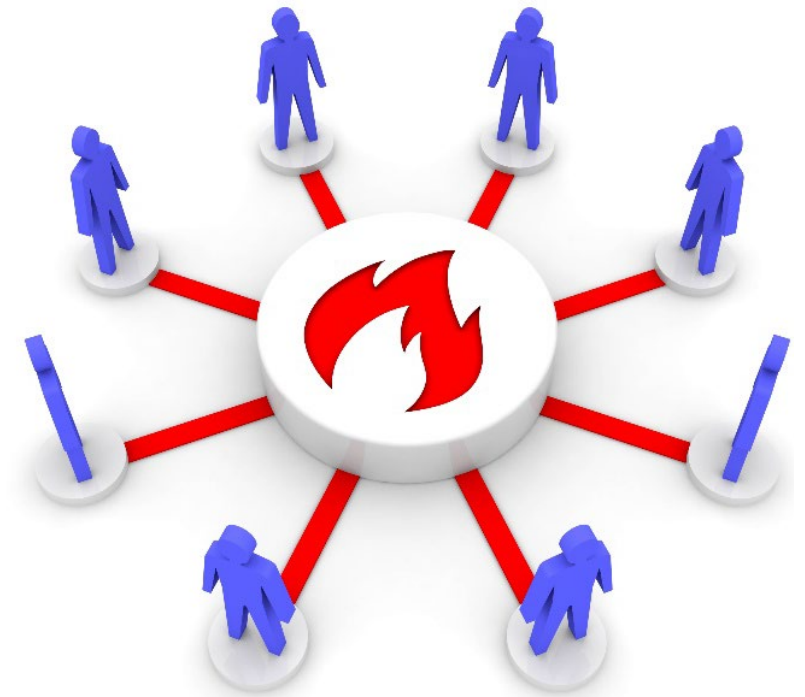
Business Continuity Plan

- The objective of business continuity planning is to ensure that organizations have the capability to **respond to and recover** from disaster situations.
- Components:
 - **Response plans** focus on the initial and near-term response.
 - **Contingency plans** focus on immediate, near-term, and short-term alternate workforce and business processes.
 - **Recovery plans** focus on the immediate, near-term, and short-term recovery of information systems, infrastructure, and facilities.
 - **Resumption plans** guide the organization back to normalcy.



Roles and Responsibilities

- Board of Directors provides **oversight** and **guidance**, **authorizes** the related policy, and is legally **accountable** for the actions of the organization.
- Executive management provides leadership.
- Business Continuity Team (BCT) has the authority to make decisions related to disaster preparation, response, and recovery.



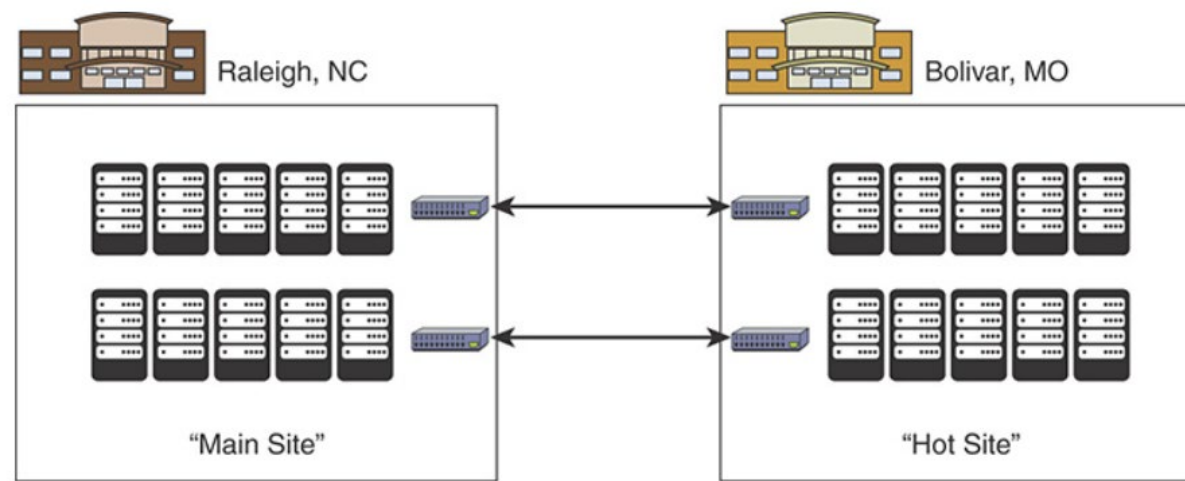
Disaster Response Plans

- Addresses what should be done immediately following a significant incident, it defines:
 - Who has the authority to declare a disaster.
 - Who has the authority to contact external entities.
 - Evacuation procedures.
 - Emergency communication & notification procedures.

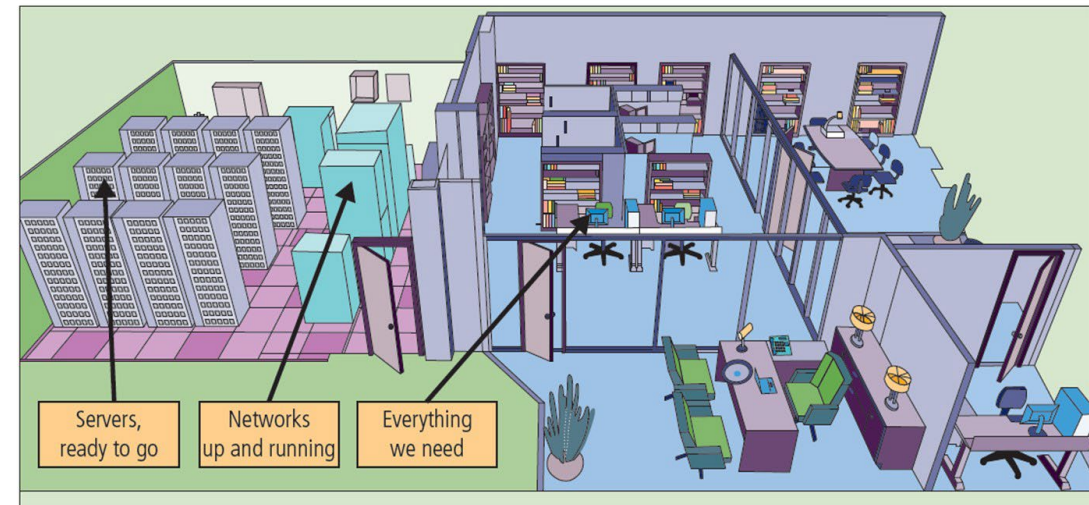


Relocation Site Types – Hot Site

- Fully operational location with redundant equipment.
- The data has been streamed to the site on a real-time basis or close to real time.



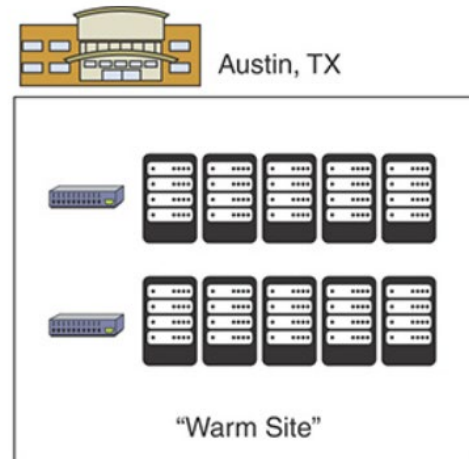
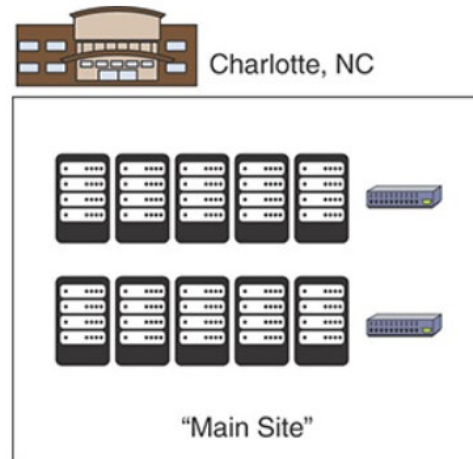
Data replicated to the hot site on a real-time or near-time basis.



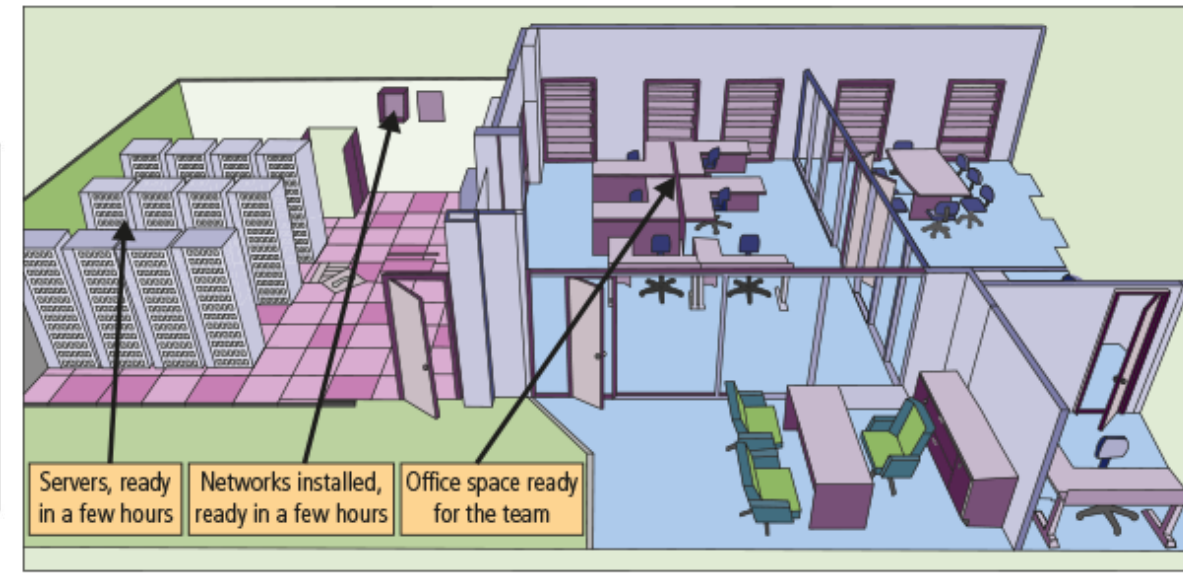
Site includes floor space, HVAC, office furniture, servers (with applications), client workstations, network and telecom connections, office equipment, and possibly on-site staff

Relocation Site Types – Warm Site

- Partially equipped with information systems and telecommunications equipment to support relocated operations.
- Spare computers there must be configured in the event of a disaster.
- Data must be restored.



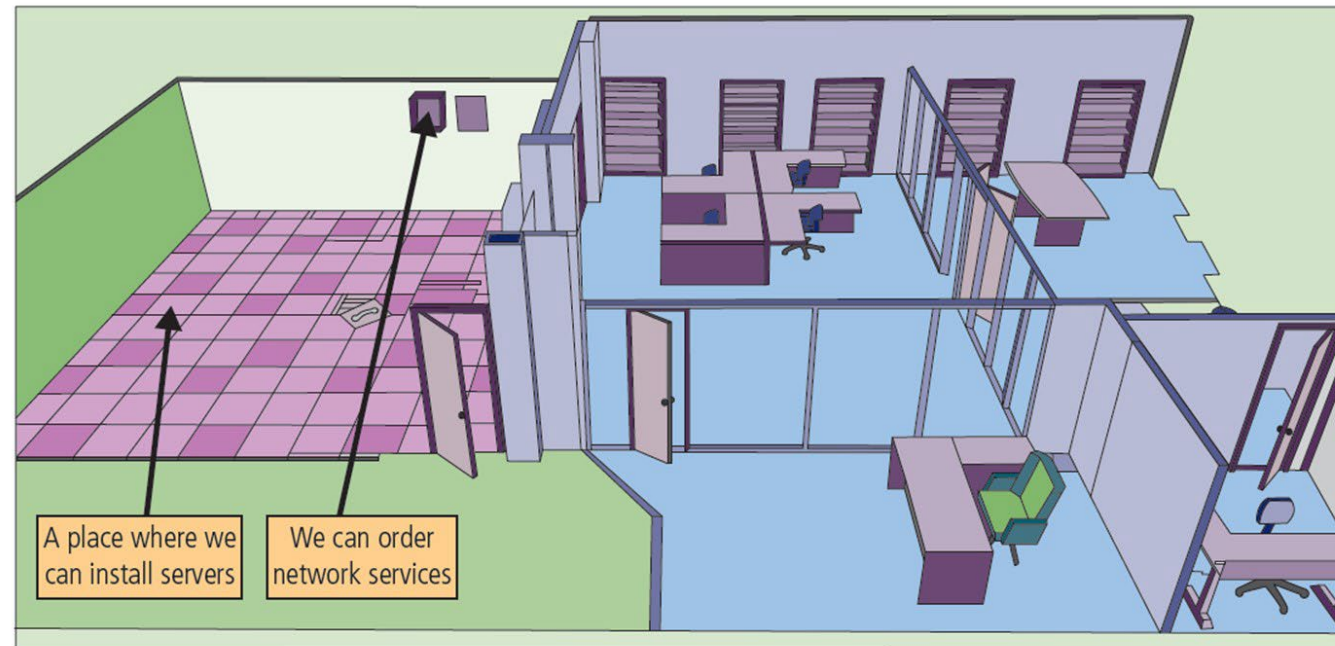
Computers and devices located at warm sites need to be configured and brought online. Data needs to be restored.



Site includes floor space, HVAC, some office furniture, and servers (without applications)

Relocation Site Types – Cold Site

- Available alternative location.
- Equipped with power, HVAC, and secure access.



Site includes floor space, HVAC, and some office furniture

Relocation Sites Comparison

Site	Cost	Hardware Equipment	Telecom-munications	Setup Time	Location
Cold site	Low	None	None	Long	Fixed
Warm site	Medium	Partial	Partial/full	Medium	Fixed
Hot site	High	Full	Full	Short	Fixed

Recovery Procedures

- All procedures should be designed, tested, documented, and approved **prior** to when the disaster strikes.
- Procedures should be written as if the person who will be following them is not intimately familiar with the information system or component.
- Procedures should explain what needs to be done, when, where, and how.
- The key is to respond fast using predefined steps.
- Recovery procedures should be reviewed annually.



Active Directory Domain Controller Recovery

Support phone numbers	Cisco Support: 800-553-2447 Microsoft Technical Support Regular Support: 888-888-9999 Business Critical: 888-888-7777
General information	Active Directory domain controllers provide authentication, DNS, and DHCP services. If a domain controller fails, the remaining domain controllers will be able to authenticate user accounts, provide DNS resolution, and assign dynamic addresses. Users may notice a degradation of service.
Configuration information	There are four Windows Server domain controllers: ▪ Two are located at the data center in rack 7G. ▪ One is located in the Building A data closet rack. It is the second device from the top. ▪ One is located in the Building B data closet rack. It is the fourth device from the top. There are five FSMO roles that are server specific: schema master, domain naming master, PDC emulator, RID master, and infrastructure master. Reference recovery/server_roles.xls for server assignments. For more information on FMSO roles, refer to http://support.microsoft.com/kb/324801.
Recovery/resumption instructions	1. If a domain controller fails, its objects and attributes will have to be removed from Active Directory, and any FSMO roles that it held must be transferred to another domain controller. Follow the steps in http://support.microsoft.com/kb/216498 to remove the data. 2. After the failed domain controller has been removed from Active Directory, a replacement can be built. A virtual machine (VM) could be used to replace a (physical) server: a. Create a cloned VM from a template. b. Assign it the host name and static IP address of the failed domain controller. c. Patch the new server and install antivirus. d. From a run command, type DCPROMO to promote the member server to be a DC. 3. Accept the default setting and follow the prompts to complete the promotion. 4. Configure DNS for zone transfers and set the forwarders. (Reference recovery/DNS_recovery_procedures for DNS configuration instructions.) 5. Configure DHCP scope information and restore assignments. (Reference recovery/DHCP_recovery_procedures for DHCP configuration instructions.)

In Practice

Emergency Response Plan Policy

Synopsis: Ensure that the organization is prepared to respond to an emergency situation.

Policy Statement:

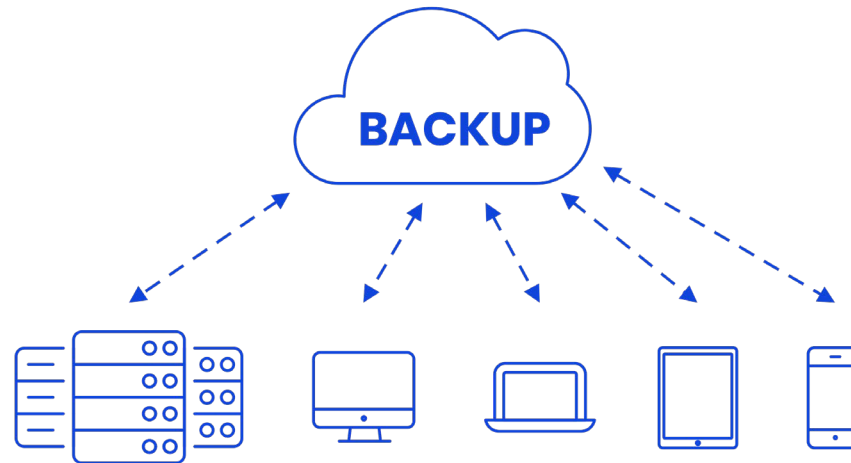
- The Chief Operating Officer is responsible for developing and maintaining the emergency response plan. The emergency response plan is a component of the enterprise business continuity plan.
- The objective of the emergency response plan is to protect the health and safety of employees, customers, first responders, and the public at large, minimizing damage to property and the environment, and set in motion response, contingency, and recovery operations.
- The emergency response plan must, at a minimum, address organizational alerts and notification, disaster declaration, internal and external communication channels, command and control centers, relocation options, and decision making authority.
- Ancillary to the response plan are OEPs and the crisis communication plan (CCP). Both plans may be utilized in conjunction with and/or referenced by the response plan.
- The Office of Human Resources is responsible for maintaining the OEP.
- The Office of Communications and Marketing is responsible for maintaining a CCP.

Topics

- Emergency Preparedness
- Business Continuity Risk Management
- The Business Continuity Plan
- Business Continuity and Disaster Recovery in Cloud Services
- Plan Testing and Maintenance

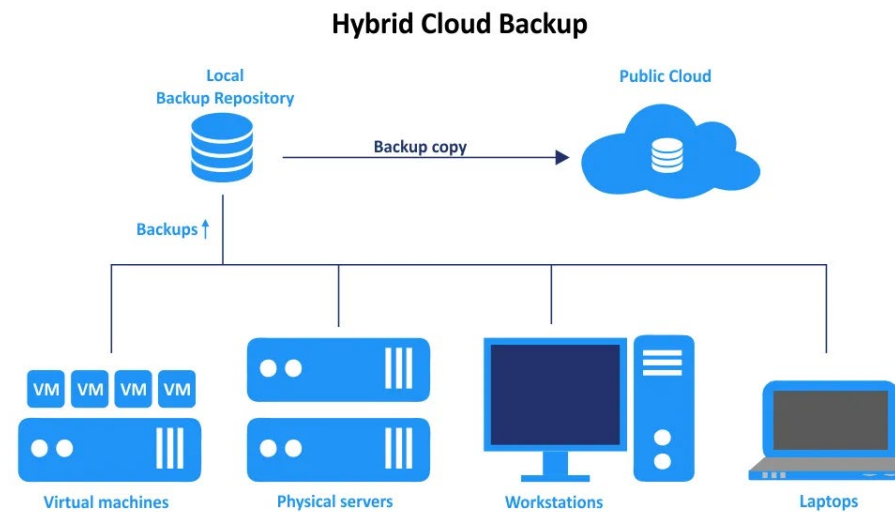
BC/DR in Cloud Computing

- Cloud services have transformed business continuity (BC) and disaster recovery (DR), offering **scalable**, **flexible**, and **cost-effective** solutions.
- These services enable businesses to replicate and store critical data across multiple geographically dispersed data centers, ensuring availability even in the face of disruptions.



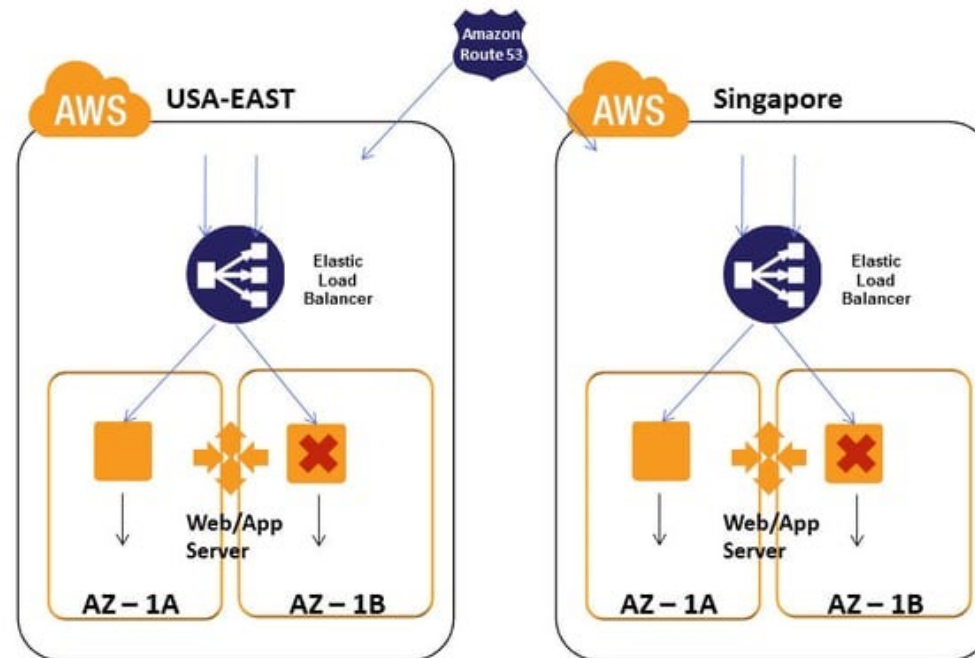
Key Components BC/DR in Cloud Computing /1

- Regularly **backing up data** to the cloud ensures that information remains accessible after a disaster.
- Cloud providers typically offer various backup solutions, including point-in-time snapshots and continuous replication.



Key Components BC/DR in Cloud Computing /2

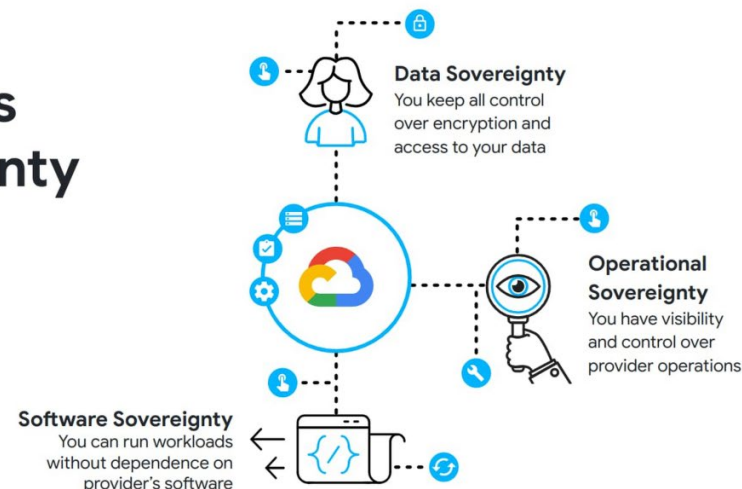
- **Redundancy** is built into cloud services, allowing for the seamless failover of operations to secondary systems or locations in the event of a failure.
- This ensures uninterrupted service and access to data, which is vital for maintaining business operations during a disaster.



Challenges of BC/DR in Cloud Computing

- Despite the advantages offered by cloud services, organizations face several challenges in implementing BC/DR strategies:
 - Data privacy and security concerns
 - Compliance with regulatory requirements
 - The need for clear service-level agreements (SLAs) with cloud providers
 - The complexity of cloud environments can make disaster recovery planning and execution more challenging

Three Pillars of Sovereignty



Best Practices for BC/DR in Cloud Services

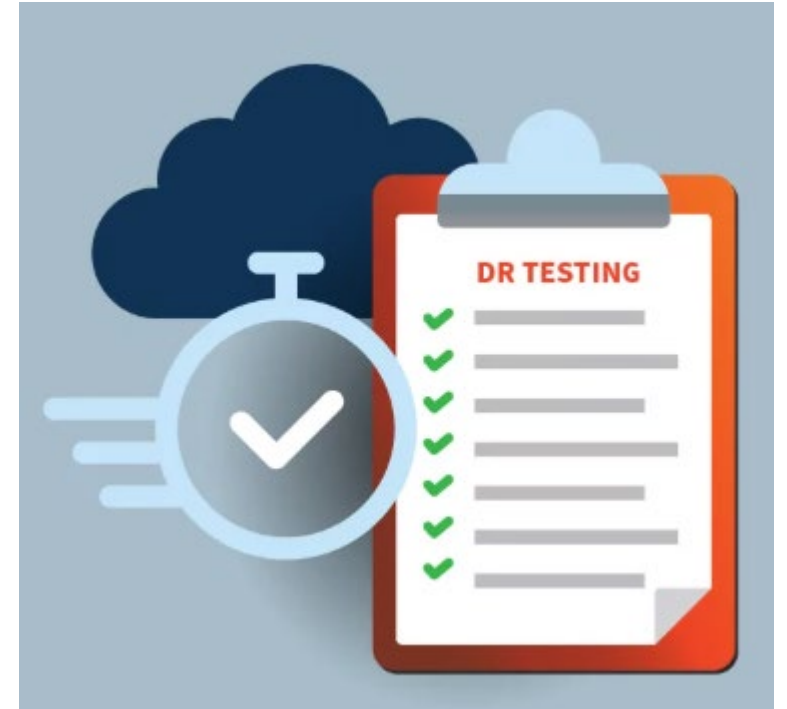
- The following are key best practices for BC/DR in cloud services:
 1. **Regularly update and test BC/DR plans:** Continuous testing and refinement of disaster recovery plans ensure their effectiveness.
 2. **Ensure clear communication:** Establish clear communication channels and protocols for disaster response and recovery efforts.
 3. **Leverage cloud flexibility:** Take advantage of the scalability and flexibility of cloud services to tailor BC/DR solutions to your organization's needs.
 4. **Focus on security and compliance:** Ensure that your BC/DR strategies adhere to industry standards and regulatory requirements to safeguard sensitive information.

Topics

- Emergency Preparedness
- Business Continuity Risk Management
- The Business Continuity Plan
- Business Continuity and Disaster Recovery in Cloud Services
- Plan Testing and Maintenance

BC/DR Plans Testing

- Proactive testing of the plan is essential.
- Until tested, the plan is theoretical at best.
- The tests should prove that the procedures and the plan are:
 - Relevant
 - Operable under adverse conditions
 - Accurate
- Tests are used to discover errors and inadequacies.



Testing Methodologies

- Three standard testing methodologies
 - **Tabletop exercises:**
 - Structured Review: focuses on a specific procedure or set of procedures.
 - Tabletop Simulation: focuses on participant readiness.
 - **Functional exercises:** allow personnel to validate plans, procedures, resource availability, and participant readiness.
 - **Full-scale testing:** conducted at the enterprise level.



BC/DR Plans Audits

- Business continuity plan audit:
 - Evaluation of how the business continuity program in its entirety is being managed.
 - Auditors must be independent.



BC/DR Plans Audits

- At a minimum, you can anticipate they will ask the following questions:
 - Is there a written business continuity policy and plan?
 - Has the business continuity policy and plan been approved by the Board of Directors?
 - How often is it reviewed and/or reauthorized?
 - How often is a BIA conducted? By whom?
 - Who is on the BCT?
 - What training have they had?
 - What training has the user community had?
 - Is there a written test plan?
 - How often is the plan tested?
 - Are the results documented?
 - If third parties are involved, what is the process for testing/verifying their procedures?
 - Who is responsible for maintaining the plan?



BC/DR Plans Maintenance

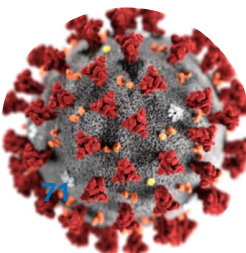
- Plan should be reviewed and edited regularly to match the changes in the company and/or the industry.
- The plan cannot be reviewed without the risk assessment being reviewed as well.
- Responsibility for maintaining the plan should be assigned to a specific role such as the ISO.



Thoughts on Business Continuity and COVID-19 Pandemic

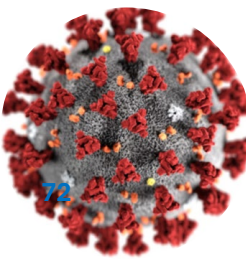
COVID-19 /1

- Most of the world discovered the need to be prepared to **work from home** during the 2020 COVID-19 pandemic.
- All noncritical employees were sent home, with most required to work from their residences as part of the **shelter-in-place strategy** to slow the spread of the virus.
- The pandemic required most organizations to **rethink how they do business**.
- Demand for **remote collaboration applications** like Microsoft Teams, Webex, Skype, and Zoom skyrocketed as did the load on most residential Internet bandwidth.
- Smaller organizations moved to social media communications like Facebook Messenger and Apple FaceTime.



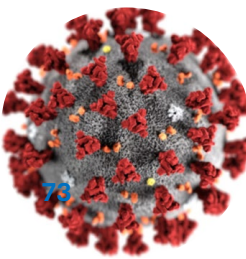
COVID-19 /2

- **Everyone contributed to effective business continuity efforts**, regardless of whether a formal plan was in place.
- In some cases, plans were developed and revised on the fly.
 - Many organizations were able to allow some or all employees to isolate themselves and work from home.
 - The expected response that would have seen employees relocate to work at alternate sites was not permitted.
 - Most major universities transitioned to online instruction.



COVID-19 /3

- The pandemic that effectively paralyzed much of the world's commerce **limited the immediate effectiveness of traditional DR and BC plans** and responses.
- Instead, organizations had to **adapt**, quickly changing their strategies and operations to maintain key functions and continue as a going concern.



In Practice

Business Continuity Testing and Maintenance Policy

Synopsis: Codify testing and maintenance requirements and responsibility.

Policy Statement:

- Reference to the business continuity plan is inclusive of plans, procedures, and ancillary documentation related to disaster preparation, response, contingency operations, recovery, resumption, training, testing, and plan maintenance.
- The Chief Operating Officer or designee is responsible for maintenance of the business continuity plan.
- The Chief Operating Officer or designee will conduct an annual review of the business continuity plan.
- The Business Continuity Team is responsible for publishing an annual testing schedule and managing the test plan. The Chief Operating Officer will report the results to the Board of Directors.
- Internal audit is tasked with managing and selecting an independent firm to conduct an annual audit of the business continuity plan. The independent audit firm will report the results to the Board of Directors or designated committee.

Topics

- Emergency Preparedness
- Business Continuity Risk Management
- The Business Continuity Plan
- Business Continuity and Disaster Recovery in Cloud Services
- Plan Testing and Maintenance

Summary

- A disaster is any event that results in damage or destruction, loss of life, or drastic change to the environment
- Emergency preparedness is a civic duty and regulatory requirement
- Continuity planning is the business practice of ensuring the execution of essential functions
- BIA identifies essential services/processes and recovery timeframes, measuring MTD, RTO, and RPO
- The components of a business continuity plan include response, contingency, recovery, and resumption plans
- A business continuity team has the authority to make decisions related to disaster preparation, response, and recovery
- Relocation sites can be hot, warm, cold, mobile, mirrored, or reciprocal
- Disaster recovery procedures should be designed, tested, documented, and approved ahead of time
- The resumption phase involves validation and deactivation
- Plans must be maintained and tested to ensure they remain relevant, operable under adverse conditions, and accurate